

EU Cyber Resilience Act

Three years until implementation

CTO Lunch Club - Friday 29 Nov 2024



Regulation 2024/2847

23 Oct 2024

Applies from 11 Dec 2027

Reporting for 'actively exploited vulnerabilities
and severe incidents' from 11 Sep 2026



Penalties

Similar to GDPR:
Up to €15m or 2.5% of global revenue
(whichever is higher)



Hi, I'm Chris

@cpswan

<https://chris.swanz.net>



Agenda

- “Risk-based” approach
- Automatic security updates
- Software Bill of Materials (SBOM)
- Impact on Open Source
- *Secure by design*



Risk based approach

Default: Expected to be **approximately 90 percent of all products** with digital elements within the common market.

Important Class I: Products related to cybersecurity functionality or functions that carry a significant risk of adversely affecting a wide range of other products or users' health and safety. Examples include browsers, password managers, physical network interfaces, and smart home virtual assistants.

Important Class II: Products that, if affected by cyber incidents, might lead to greater negative effects due to the nature of their cybersecurity-related function or the performance of another function with significant risk. Examples include hypervisors, firewalls, and tamper-resistant microprocessors.

Critical Products: Products that have cybersecurity-related functionality, perform functions that carry a significant risk of adverse effects, and are considered critical dependencies for EU NIS2 Directive essential entities.



Automatic security updates

“put in place processes to ensure that products with digital elements include functions that enable the notification, distribution, download and installation of security updates automatically”

Users should be able to opt out

Security updates shouldn't be tied to functionality changes



Software Bill of Materials - SBOM



<https://www.cisa.gov/sbom>

Impact on open source

“Product”

“Manufacturer”



Secure by design



Review

- “Risk-based” approach
- Automatic security updates
- Software Bill of Materials (SBOM)
- Impact on Open Source
- *Secure by design*



Resources

<https://blog.meterian.com/2024/11/20/eu-cyber-resilience-act-key-updates-on-sbom-compliance/>

<https://www.cybeats.com/blog/why-sboms-are-critical-to-complying-with-the-eu-cyber-resilience-act>

<https://blog.nlnetlabs.nl/what-i-learned-in-brussels-the-cyber-resilience-act/>

https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=OJ:L_202402847

<https://www.thestack.technology/linux-foundation-europe-says-eu-cyber-security-law-now-not-as-terrible/>



Resources cont.

<https://lwn.net/Articles/944300/>

<https://www.forbes.com/sites/michaelharley/2024/03/28/eu-cybersecurity-laws-kill-porsches-718-boxster-and-cayman-early/>

<https://www.lawfaremedia.org/article/the-cyber-resilience-act--an-accidental-european-alien-torts-statute>

<https://eclipse-foundation.blog/2023/01/15/european-cyber-resiliency-act-potential-impact-on-the-eclipse-foundation/>

